

APLICACIONES DISTRIBUIDAS

Seguridad y Confiabilidad en Sistemas Distribuidos

Tema 4 · Unidad 1 · 18 – 24 de Mayo del 2026

 **Resultado de Aprendizaje:** Analiza las características y principios de los SD, evaluando sus ventajas, limitaciones y retos desde una perspectiva crítica e interdisciplinaria.

Evaluaciones esta semana: FORM-AC-01 (Análisis de Caso en clase) · TA-IND-01 (Informe Académico Individual)



Glosario de Siglas — Semana 3

SD = Sistema Distribuido

Colección de nodos autónomos que aparecen como uno solo

CIA = Confidentiality · Integrity · Availability

La triada de seguridad — los 3 pilares

TLS = Transport Layer Security

Protocolo de cifrado de red (sucesor de SSL)

JWT = JSON Web Token

Token firmado para autenticación (RFC 7519)

OAuth = Open Authorization

Protocolo de autorización delegada — versión actual: 2.0

RBAC = Role-Based Access Control

Permisos asignados a roles, no directamente a usuarios

ABAC = Attribute-Based Access Control

Permisos basados en atributos del usuario y contexto

DoS = Denial of Service

Ataque que agota los recursos de un servicio

DDoS = Distributed Denial of Service

DoS lanzado desde múltiples fuentes simultáneas

MTBF = Mean Time Between Failures

Tiempo promedio entre fallos del sistema

MTTR = Mean Time To Recovery

Tiempo promedio de recuperación tras un fallo

SLA = Service Level Agreement

Acuerdo de Nivel de Servicio — define disponibilidad mínima

RTO = Recovery Time Objective

Tiempo máximo aceptable de caída del sistema

RPO = Recovery Point Objective

Pérdida máxima aceptable de datos (medida en tiempo)

Agenda — Semana 3 · Tema 4: Seguridad y Confiabilidad

01

Amenazas y Vulnerabilidades

Triada CIA (C-I-A) · DoS / DDoS · Man-in-the-Middle (MitM) · Inyección · Eavesdropping

02

Autenticación, Autorización y Cifrado

JWT (JSON Web Token) · OAuth 2.0 (Open Authorization) · RBAC · TLS · AES / RSA

03

Tolerancia a Fallos

Taxonomía Cristian (1991) · MTBF · MTTR · Circuit Breaker · Redundancia y Replicación

04

SLA y Alta Disponibilidad

SLA (Service Level Agreement) · Los 'nines' · RTO (Recovery Time Obj.) · RPO (Recovery Point Obj.)

01 · Amenazas y Vulnerabilidades en SD

Triada CIA: Confidentiality (solo autorizados leen) · Integrity (sin alteración no detectada) · Availability (siempre accesible). **Toda amenaza ataca ≥ 1 pilar.**

DoS / DDoS

Denial of Service / Distributed DoS

Inunda el servidor con peticiones para agotar sus recursos. DDoS usa miles de nodos comprometidos (botnet). Ataca: Availability (A).

Caso real: Ataque a GitHub, Feb 2018: 1.35 Tbps de tráfico. Mitigado por Akamai en 10 min.

Inyección de código

SQL Injection, Command Injection

Código malicioso insertado como entrada que el sistema ejecuta como instrucción legítima. Puede afectar múltiples nodos. Ataca: C, I, A.

Caso real: Heartland 2008: SQL Injection → 130M tarjetas de crédito robadas.

Man-in-the-Middle

MitM — Intercepción activa

El atacante se interpone entre dos nodos y lee o modifica mensajes en tránsito. Posible sin TLS. Ataca: C e I.

Caso real: ARP Spoofing en red local. Contramedida: TLS 1.3 + certificados verificados + HSTS.

Eavesdropping

Escucha pasiva del tráfico de red

El atacante monitorea el tráfico sin modificarlo. Sin cifrado, captura JWTs, contraseñas y datos sensibles. Ataca: Confidentiality (C).

Caso real: Contramedida: cifrado extremo a extremo con TLS 1.3 incluso en red interna.

02 · Autenticación, Autorización y Cifrado en SD

Autenticación: ¿Quién eres? (identidad verificada) · **Autorización:** ¿Qué puedes hacer? (permisos) · **Cifrado:** ¿Nadie más puede leer? (confidencialidad)

JWT *JSON Web Token (RFC 7519)*

Estructura: Header.Payload.Signature

Header: algoritmo de firma (HS256, RS256)

Payload: claims: sub (subject), exp (expiration), roles

Signature: HMAC(header+payload, secret_key)

Flujo: POST /login → servidor retorna JWT → cliente adjunta en header:

Authorization: Bearer <token>

OAuth 2.0 *Open Authorization*

Propósito: autorización delegada (no autenticación directa).

Roles: Resource Owner · Client (app) · Authorization Server · Resource Server.

Flujo más común: Authorization Code + PKCE (Proof Key for Code Exchange).

PKCE: protege el código de autorización en apps móviles/SPA.

Ejemplo real: 'Login con Google' → Google actúa como Authorization Server.

RBAC *Role-Based Access Control*

Permisos → Roles → Usuarios. Ej: Administrador (CRUD) · Docente (read+write propios) · Estudiante (read only).

ABAC (Attribute-Based): permisos según atributos del usuario, recurso y contexto. Más flexible pero más complejo de implementar.

Cifrado *Simétrico y Asimétrico*

AES (Advanced Encryption Standard): simétrico, misma clave para cifrar/descifrar. AES-256 es el estándar actual.

RSA (Rivest-Shamir-Adleman): asimétrico, clave pública cifra / clave privada descifra. Base de TLS.

TLS 1.3 = AES para datos + RSA/ECDH para intercambio de claves. Elimina algoritmos débiles.

03 · Tolerancia a Fallos — Detección y Recuperación

Taxonomía de Cristian (1991): Crash · Omisión de envío · Omisión de recepción · Temporización · Bizantino — *cada tipo requiere estrategia diferente de detección y recuperación.*

Fallo tipo: Crash

El proceso deja de ejecutarse completamente. El más simple de detectar via heartbeat.

Detección: Heartbeat + timeout → ECONNRESET o TCP keepalive.

Recuperación: Reinicio automático (Docker restart policy, systemd). Elección de nuevo líder (Bully/Ring/Raft).

Fallo tipo: Omisión

El proceso existe pero no envía o no recibe ciertos mensajes. Más difícil de detectar que crash.

Detección: ACK (acknowledgment) esperado + retransmisión con backoff exponencial.

Recuperación: Retransmitir el mensaje. Asumir crash si supera max_retries.

Fallo tipo: Temporización

El proceso responde, pero fuera del timeout. Indistinguible de crash desde la perspectiva del receptor.

Detección: Timeout estricto con setTimeout(). Circuit Breaker en estado OPEN.

Recuperación: Circuit Breaker: CLOSED → OPEN → HALF-OPEN → CLOSED.

Fallo tipo: Bizantino

El proceso envía mensajes incorrectos o contradictorios intencionalmente. El más difícil de tolerar.

Detección: Firmas digitales + checksums. Quórum de confirmación de al menos $2f+1$ nodos.

Recuperación: BFT (Byzantine Fault Tolerance): PBFT, Tendermint. Blockchain usa variantes de BFT.

MTBF = Mean Time Between Failures · **MTTR** = Mean Time To Recovery · **Disponibilidad** = $\text{MTBF} / (\text{MTBF} + \text{MTTR})$

04 · SLA (*Service Level Agreement*) y Alta Disponibilidad

SLA (Service Level Agreement = Acuerdo de Nivel de Servicio): contrato formal que define: disponibilidad mínima garantizada, tiempos de respuesta máximos, soporte técnico y penalizaciones por incumplimiento.

Disponibilidad — Los 'Nines'

Disponibilidad = $MTBF / (MTBF + MTTR)$

90.0% 1 nine ~36.5 días/año

99.0% 2 nines ~87.6 horas/año

99.9% 3 nines ~8.76 horas/año

99.99% 4 nines ~52.6 min/año

99.999% 5 nines ~5.26 min/año

99.9999% 6 nines ~31.5 seg/año

RTO y RPO

RTO *Recovery Time Objective*

Tiempo máximo que puede estar el sistema caído antes de causar daño inaceptable.

Ej: RTO=4h → el sistema debe estar operativo en max. 4h tras el fallo.

RPO *Recovery Point Objective*

Máxima pérdida de datos aceptable, medida en tiempo.

Ej: RPO=30min → los backups deben ser cada 30 min como máximo.

Técnicas HA: Replicación activa-activa · Load Balancer · Auto-scaling · Multi-región · Chaos Engineering



FORM-AC-01 — Análisis de Caso: Fallo en SD Real

Campo	Detalle
Código	FORM-AC-01 (Actividad Grupal en Clase — GA)
Semana	3 — 18 al 24 de Mayo del 2026
Modalidad	Grupal (3-4 estudiantes) — trabajo en clase · 60-75 minutos
Entregable	Formulario completado + exposición oral de 5 min al docente
 Estructura del análisis (aplicar los 4 subtemas del Tema 4)	

- 1. Descripción del fallo:** ¿Qué sistema falló? ¿Cuándo? ¿Cuánto duró? ¿Qué impacto tuvo? (datos cuantitativos: usuarios afectados, tiempo de downtime, pérdidas económicas). Citar la fuente primaria (post-mortem oficial).
- 2. Clasificación (Cristian):** ¿Qué tipo de fallo fue según la taxonomía de Cristian? ¿Crash, omisión, temporización o byzantino? Justificar con evidencia específica del post-mortem.
- 3. Análisis CIA:** ¿Qué pilar de CIA (Confidentiality, Integrity, Availability) fue comprometido? ¿Hubo violación de seguridad asociada al fallo?
- 4. Disponibilidad y SLA:** Calcular disponibilidad real durante el incidente con la fórmula $MTBF/(MTBF+MTTR)$. ¿Se cumplió el SLA declarado? ¿Cuál fue el RTO real?
- 5. Lección para el PFC:** ¿Qué mecanismo concreto (con nombre técnico) implementarías en el PFC para prevenir o mitigar este tipo de fallo?

Casos sugeridos (docente asigna 1 por grupo): AWS us-east-1 (2017) · Facebook (2021) · Cloudflare (2020) · GitLab (2017) · British Airways (2017)



TA-IND-01 — Informe Académico Individual · Análisis Crítico U1

Campo	Detalle
Código	TA-IND-01 (Trabajo Autónomo Individual N° 01)
Modalidad	INDIVIDUAL — cada estudiante entrega su propio documento
Entrega	Semana 3 — máximo 24 de Mayo del 2026
Formato	LaTeX · compilar sin errores · ≥ 4 referencias IEEE con DOI
Extensión	Mínimo 4 páginas de contenido (sin portada ni bibliografía)

Estructura del informe en LaTeX (6 secciones obligatorias)

Sec. 1: Portada + Abstract bilingüe (español e inglés, 150-200 palabras c/u)

Sec. 2: Transparencias ANSA: tabla de las 8, estado (Sí/Parcial/No) y justificación técnica en el SD elegido

Sec. 3: Taxonomía de Cristian: ≥ 2 tipos de fallos con evidencia real, detección, recuperación, cálculo MTBF/MTTR

Sec. 4: Triada CIA: evaluación de los 3 pilares + mecanismos autenticación/autorización/cifrado + amenaza con mitigación

Sec. 5: Posición CAP/PACELC: clasificación con justificación técnica + modelo de consistencia del SD elegido

Sec. 6: Conexión con el PFC: ≥ 2 decisiones de diseño fundamentadas en la Unidad 1 (mínimo 200 palabras)

 LaTeX que no **compila** = 0 pts en formato · Dos informes idénticos = 0 para ambos · Referencias sin DOI no se contabilizan

Resumen Semana 3 — Tema 4: Seguridad y Confiabilidad

Amenazas — Triada CIA

CIA = C-I-A. DoS/DDoS atacan Availability. MitM ataca C e I. Inyección ataca C+I+A. Eavesdropping ataca Confidentiality. Contramedida universal: TLS.

Autenticación y Cifrado

JWT = token firmado (Header.Payload.Signature). OAuth 2.0 = autorización delegada. RBAC = permisos por roles. TLS = cifrado en tránsito. AES/RSA = simétrico/asimétrico.

Tolerancia a Fallos

Cristian: Crash · Omisión · Temporización · Byzantino. MTBF = tiempo entre fallos. MTTR = tiempo de recuperación. Disponibilidad = $\frac{MTBF}{MTBF+MTTR}$. Circuit Breaker previene cascade failures.

SLA y Alta Disponibilidad

SLA = Acuerdo Nivel Servicio. Los 'nines': 99.9% = 8.76h/año downtime. RTO = tiempo máx. caído. RPO = pérdida máx. de datos. Técnicas HA: replicación, load balancer, auto-scaling.

 Conexión con GA-SUM-01 (Semana 4): el fundamento teórico sección 4.4 'Tolerancia a Fallos, Seguridad y Teorema CAP' usa directamente los conceptos de hoy.

Preguntas para reflexión — aplicar al PFC:

1. ¿Qué tipo de fallo (Cristian) es más probable en el PFC y cómo lo detectarías?
2. ¿Qué nivel de disponibilidad ('nines') necesita el PFC? ¿Cuál sería el SLA realista?
3. ¿JWT o OAuth 2.0 para autenticar usuarios entre microservicios del PFC? ¿Por qué?

 Semana 4: Tema 5 — Coordinación y Consistencia · Entrega GA-SUM-01 · Exposiciones Corte 1